Institut Universitaire de Technologie de Nice - Côte d'Azur
Département Télécommunications Année 2025-2026

T.P. de RÉSEAUX – Configuration d'une topologie résiliente face à divers menaces

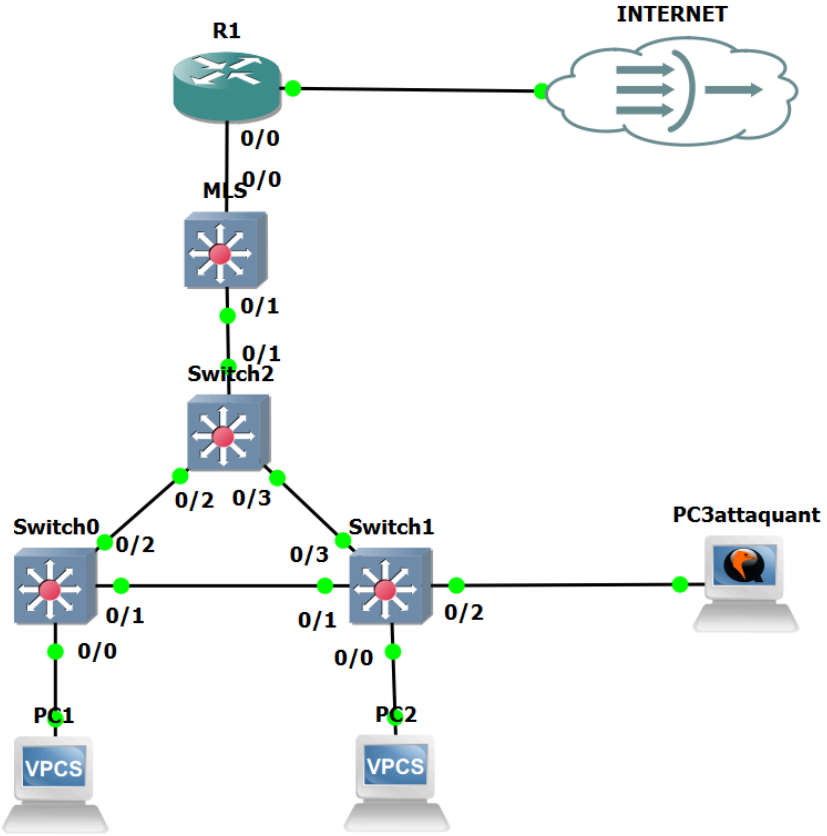
"Opération Madagascar : Infiltration du zoo"

Par Thibault ROMMES et Mattéo RECOQUILLON

I - Préambule

Cette manipulation vise à comprendre l'exploitation des vulnérabilités inhérentes aux protocoles de couche liaison de données et de couche réseau (niveaux 2 et 3), ainsi qu'à configurer de manière pertinente les équipements d'interconnexion pour parer à ces menaces. À travers le scénario ludique de l'« Opération Madagascar », notre topologie sera utilisée afin de simuler l'usurpation des services d'adressage et de routage locaux (DHCP Spoofing et ARP Poisoning) contrée par les fonctions de DHCP Snooping et de DAI, d'expérimenter le contournement des cloisonnements logiques (VLAN Hopping), d'éprouver la résilience matérielle par la saturation des tables d'adresses physiques (MAC Flooding) gérée via le Port Security, et enfin de manipuler l'élection de la topologie de l'arbre recouvrant (STP Spoofing) bloquée par l'activation du BPDU Guard.

L'infrastructure exploitée repose sur un ensemble de commutateurs et d'un routeur Cisco, auxquels sont connectés des hôtes clients légitimes (PC1 et PC2) ainsi qu'une machine virtuelle Debian faisant office d'équipement attaquant branchée sur le port d'accès eth0/2. Les commutateurs seront donc étudiés d'abord dans leur configuration de base vulnérable , puis ils seront reconfigurés progressivement comme de véritables équipements de protection du réseau interne mettant en œuvre une sécurité multicouche en profondeur. L'ensemble de la maquette illustrera la dynamique d'escalade entre un intrus cherchant à prendre le contrôle du trafic et l'administrateur devant verrouiller physiquement et logiquement chaque faille de son infrastructure.



II - Préparation

Cette étape de préparation consiste à la mise en place des pré-requis nécessaires au bon déroulement de ce TP. A savoir, l'obtention d'adresses IP via le DHCP pour les PC légitimes et une IP static pour le PC Debian attaquant, l'activation de l'interface ens3 sur l'attaquant, ainsi que les différents outils d'attaques que nous allons utiliser.

PARTIE 1 : DÉPLOIEMENT DE L'INFRASTRUCTURE INITIALE

Objectif de cette phase : Mettre en place une topologie réseau fonctionnelle, segmentée, avant de procéder aux simulations d'attaques.

1.1. Architecture logique (VLANs) Sur l'ensemble des équipements de commutation de la topologie (Switch0, Switch1, Switch2, MLS), vous devez provisionner la base de données VLAN en respectant le cahier des charges suivant :

- VLAN 2 : Nommé VLAN_PC0 (Réseau de production 1).
- VLAN 3 : Nommé VLAN_PC1 (Réseau de production 2).
- VLAN 99 : Nommé NATIVE (Réservé exclusivement au trafic non-étiqueté des Trunks).
- VLAN 100 : Nommé UNUSED_PORTS (VLAN "poubelle").

1.2. Spanning-Tree et Haute Disponibilité

- Afin d'assurer une convergence rapide de la topologie, le protocole Rapid-PVST doit être activé globalement sur tous les commutateurs.
- L'élection du pont racine ne doit pas être laissée au hasard : le Switch2 doit être forcé en tant que Root Bridge pour l'ensemble des VLANs de données (Priorité fixée à 4096).

1.3. Interconnexions (Trunks) et Accès utilisateurs

- Liens Trunks : L'intégralité des liens inter-commutateurs doit être configurée statiquement en mode Trunk (avec l'encapsulation dot1q forcée sur le routeur).
- Le VLAN natif de ces liens doit obligatoirement être le VLAN 99.
- Appliquez un filtrage strict : seuls les VLANs 2, 3 et 99 sont autorisés à traverser ces liens.
- Ports d'accès : Les interfaces connectant les machines clientes doivent être configurées en mode accès dans leur VLAN respectif et bénéficier de la fonctionnalité portfast.

1.4. Rôles des VLANs

- Ports inutilisés : L'intégralité des interfaces physiques non utilisées sur chaque commutateur doit être affectée au VLAN 100 et désactivée administrativement (shutdown).
- Gestion : Affectez la passerelle par défaut 172.16.0.254 aux commutateurs d'accès pour garantir leur joignabilité hors-réseau.

1.5. Routage Inter-VLAN et Services IP (Routeur)

- Encapsulation : Le routeur principal assurera le routage entre les différents réseaux. Configurez les sous-interfaces nécessaires sur son interface principale (Fa0/0) pour prendre en charge le trafic des VLANs 2, 3 et 99 (l'interface .99 devra être déclarée comme native). L'adresse IP physique du routeur pour les VLANs de production sera en .251.
- Redondance HSRP : Déployez le protocole HSRP sur les sous-interfaces de production. L'adresse IP virtuelle sera configurée en .254.
- Serveur DHCP : Le routeur doit agir comme serveur DHCP pour distribuer dynamiquement les adresses IP aux hôtes des réseaux 192.168.2.0/24 et 192.168.3.0/24. N'oubliez pas de leur fournir l'adresse de la passerelle virtuelle HSRP.

PARTIE 2 : CONFIGURATION DU MATERIEL

2.1. Obtenir une IP via DHCP sur PC1 et PC2 :

PC1> ip dhcp
PC2> ip dhcp

2.2. Configuration de la machine Debian (connectée sur eth0/2) :

debian@debian:~$ sudo ip addr add 192.168.3.50/24 dev ens3
debian@debian:~$ sudo ip link set ens3 up
debian@debian:~$ sudo ip link set ens3 promisc on

2.3. Installation des outils nécessaires (Yersinia, Macof et Arpspoof) :

Voir le manuel d'installation en Annexe

III - Manipulation

Sujet : *Les amis d'Alex le lion ont été capturés puis enfermés dans le mythique Zoo de Central Park. Dans sa mission Alex sera accompagné des pingouins de Madagascar, ensemble ils tenteront de s'infiltrer dans le zoo afin de libérer leurs amis. Pour ce faire, ils utiliseront des techniques d'usurpations d'identité (MiTM) et de déni de service (DoS).*

Attaque 1 : DHCP Spoofing

Contexte : *Alex se déguise en chef des gardiens, dans le but de distribuer de fausses feuilles de route aux nouveaux gardiens qui prennent leur service, afin de contrôler leurs déplacements vers de mauvaises directions.*

Objectif de l'attaque : Création d'un Rogue DHCP via Yersinia. Le pirate distribue de fausses adresses IP et se déclare comme "Passerelle par défaut" pour intercepter tout le trafic vers Internet.

Préparatifs : Couper les ports d'accès en direction du routeur afin d'éviter que les PC obtiennent leur adresse via le routeur (Switch1 : eth0/1, eth0/3).

Switch1(config)# int eth0/1, eth0/3
Switch1(config-if)# shutdown

Pour effectuer cette attaque nous allons utiliser l'outil Yersinia :

debian@debian:~$ sudo yersinia -I

Touche i : sélectionner la carte ens3

Touche g : DHCP

Touche x : Menu des attaques

Touche 2 : creating DHCP rogue server

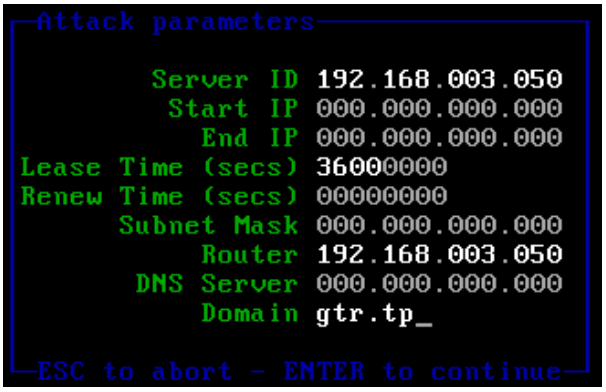
Pour l'attaque DHCP Rogue Server il nous faudra remplir les champs suivants :

Server ID : IP de l'attaquant

Lease Time : 3600 secondes

Router : IP de l'attaquant

Domain : nom de domain quelconque



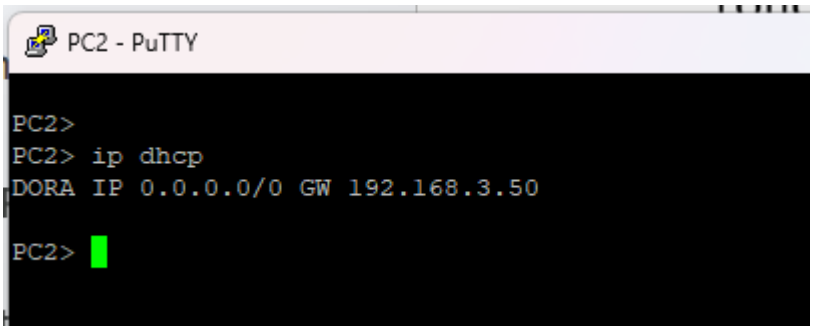
Résultat : le PC victime a accepté la configuration piégée du faux serveur et a défini l'ordinateur de l'attaquant (192.168.3.50) comme sa nouvelle passerelle par défaut, ce qui détournera tout son trafic futur vers le pirate.

Q1 : Rappelez brièvement les 4 étapes du processus DHCP (DORA). À quel moment précis l'attaquant intervient-il pour devancer le vrai serveur DHCP ?

Q2 : Pourquoi cette attaque est-elle souvent appelée "course de vitesse" (*Race Condition*) entre le serveur légitime et l'attaquant ?

Q3 : Sur une machine victime, comparez le résultat de la commande "sh ip" avant et après l'attaque. Quelles sont les informations critiques que l'attaquant a modifiées ?

illustration : obtention du faux serveur dhcp



Défense 1 : DHCP Snooping

***Contexte**: Le directeur du zoo se rend compte de la supercherie et met en place un système de tampons officiel sur les feuilles de route. Les documents venant de sources non certifiées sont ignorés.*

Objectif de la défense : Neutraliser les faux serveurs en bloquant toute distribution d'adresses IP provenant de ports non de confiance, tout en construisant un registre infalsifiable des machines légitimes du réseau.

Switch1(config)# ip dhcp snooping
Switch1(config)# ip dhcp snooping vlan 3
Switch1(config)# no ip dhcp snooping information option

Sur le port de confiance vers le serveur légitime :

Switch1(config)# int eth0/3
Switch1(config-if)# ip dhcp snooping trust
Switch1(config-if)# no shutdown
Switch1(config)# int eth0/1
Switch1(config-if)# no shutdown

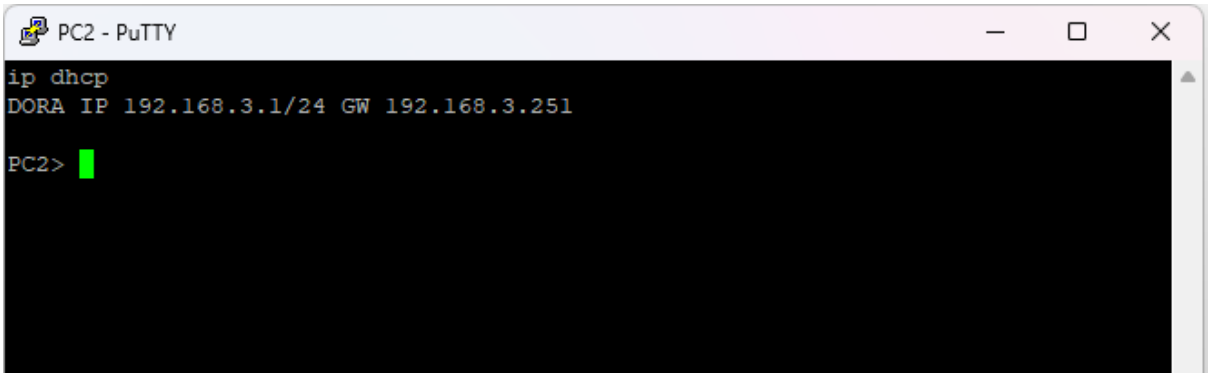
Résultat : La défense du switch a bien fonctionné, en constatant que le pc a bien pu recevoir son adresse ip.

Q1 : Expliquez la différence fondamentale entre un port "Trusted" et un port "Untrusted" . Sur quel(s) port(s) spécifique(s) du switch doit-on impérativement activer le mode trust ?

Q2 : Si le PC attaquant essaie d'envoyer une proposition d'adresse IP sur un port configuré en "Untrusted", que va faire le switch ?

Q3 : Expliquez comment le registre de sécurité du switch permet de lier l'adresse MAC d'un appareil à son adresse IP pour empêcher toute usurpation d'identité sur le réseau.

illustration : obtention de l'@ IP par DHCP



Attaque 2 : ARP Poisoning

Contexte **:** *Alex tente un nouveau stratagème, il ordonne aux pingouins de modifier les fréquences des radios des gardiens sur sa propre fréquence afin d'écouter toutes leurs communications.*

Objectif de l'attaque : Le but est de corrompre le cache ARP de la machine victime en associant la propre adresse MAC du pirate à l'adresse IP de la passerelle légitime (le routeur) ici *192.168.3.251*, afin de détourner et d'intercepter silencieusement tout son trafic réseau.

Préparatif : Passer le port eth0/2 dans la vlan3.

Switch1(config)# int eth0/2
Switch1(config-if)# switchport access vlan 3

Ensuite nous utiliserons l'outil arpspoof pour envoyer un paquet ARP malveillant et ainsi se faire passer pour un routeur de confiance auprès des PC.

debian@debian:~$ sudo arpspoof -i ens3 -t 192.168.3.1 192.168.3.251

Un PC ne remplit son carnet d'adresses (sa table ARP) que lorsqu'il a besoin de communiquer, on va engager se remplissage en pingant un équipement :
PC2> ping 192.168.3.251

Vérifier l'impact sur le PC 2 :
PC2> show arp

Résultat : On observe l'adresse MAC du PC attaquant ce qui signifie que le PC considère bien le PC attaquant comme passerelle par défaut :

Q1 : Dans notre commande arpspoof, nous ciblons l'adresse IP 192.168.3.251. À quel équipement correspond cette adresse et pourquoi l'attaquant choisit-il spécifiquement d'usurper cette identité ?

Q2 : Pourquoi était-il nécessaire de faire un ping depuis le PC2 vers le routeur avant de pouvoir observer le résultat de l'attaque ?

Q3 : En comparant la table ARP du PC2 avant et après l'attaque, quel changement précis et observable prouve que l'empoisonnement a fonctionné ?

illustration : @Mac attaquant

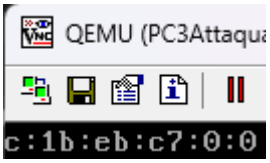
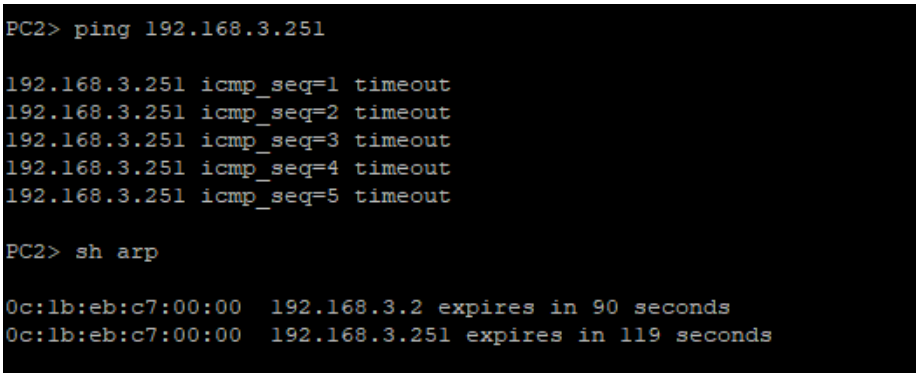


illustration : preuve de la réussite de l'attaque



```
PC2> ping 192.168.3.251

192.168.3.251 icmp_seq=1 timeout
192.168.3.251 icmp_seq=2 timeout
192.168.3.251 icmp_seq=3 timeout
192.168.3.251 icmp_seq=4 timeout
192.168.3.251 icmp_seq=5 timeout

PC2> sh arp

0c:1b:eb:c7:00:00  192.168.3.2 expires in 90 seconds
0c:1b:eb:c7:00:00  192.168.3.251 expires in 119 seconds
```

Défense 2 : Dynamic ARP Inspection (DAI)

Contexte : *Le directeur ne recevant plus d'informations, découvre l'entourloupe des pingouins et instaure un croisement systématique de la liste des fréquences fiables avec le registre des fréquences officielles stockées dans la salle de contrôle. Alex se fait attraper par les gardes qui l'envoie dans un enclos isolé (n°100).*

Objectif de la défense : Contrôler les attaques d'usurpation (ARP Poisoning) en interceptant et en détruisant tout paquet ARP dont la correspondance IP/MAC ne figure pas dans le registre de confiance officiel établi au préalable par le DHCP Snooping.

Switch1(config)# ip arp inspection vlan 3
Switch1(config)# int eth0/3
Switch1(config-if)# ip arp inspection trust

Résultat : Refaites l'attaque, elle ne marche plus, on observe sur le switch 1 un message indiquant qu'il vient de détruire le paquet ARP invalide venant du port eth0/2.

Q1 : Sur quelle autre fonctionnalité de sécurité la défense DAI s'appuie t-elle obligatoirement pour fonctionner ?

Q2 : Pourquoi est-il obligatoire de configurer le port relié au routeur en mode 'trust' (confiance) lors de la mise en place du DAI ?

illustration : destruction du paquet arp par DAI

```
Switch1(config)#
*Mar 20 18:54:00.357: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Res) on Et0/
2, vlan 3.([ca01.085f.0000/192.168.3.251/0050.7966.6801/192.168.3.1/18:54:00 UTC
 Fri Mar 20 2026])
Switch1(config)#
```

Attaque 3 : VLAN Hopping

Contexte : *Alex trouve un subterfuge pour accéder aux enclos de ses amis (n°2 et 3). L'enclos n'ayant pas de toiture, il parvient à l'escalader.*

Objectif de l'attaque : Forcer un switch à transformer un simple port d'accès en un lien "Trunk" (notamment via l'envoi de trames de négociation frauduleuses), afin de s'échapper du réseau virtuel d'origine et d'accéder illégalement au trafic de tous les autres VLANs de l'infrastructure.

Préparatifs : S'assurer que le switch accepte la négociation par paquets DTP

Switch1(config)# int eth0/2
Switch1(config-if)# no switchport nonegotiate
Switch1(config-if)# switchport mode dynamic auto

Nous utiliserons yersinia pour envoyer la requête DTP permettant de passer le port eth0/2 en mode trunk.
debian@debian:~$ sudo yersinia -I

Touche i : sélectionner la carte ens3

Touche g : DTP

Touche x : Menu des attaques

Touche 1 : enabling trunking

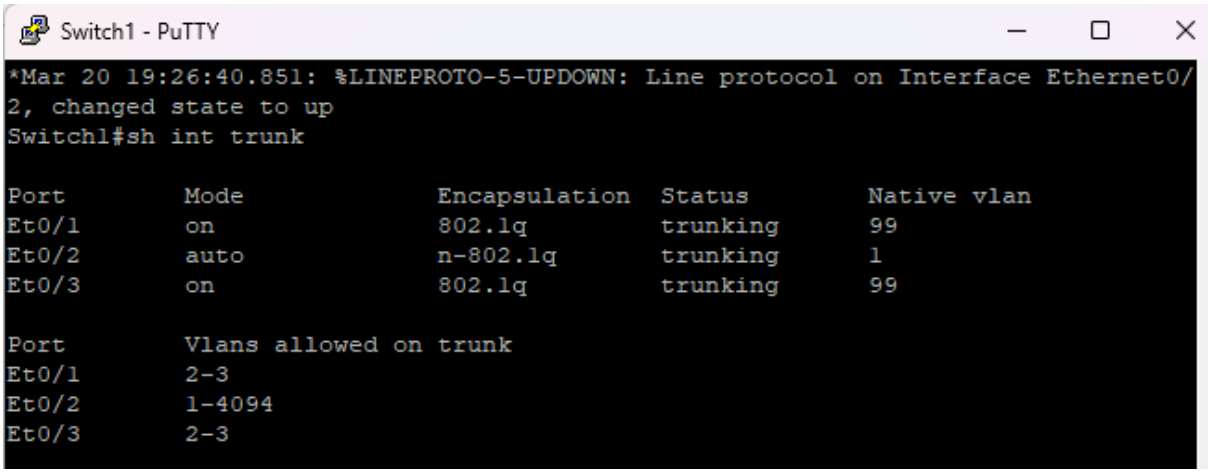
Résultat : le port de l'attaquant (Et0/2) a négocié dynamiquement un lien trunking, lui ouvrant ainsi un accès illégal à la totalité des réseaux virtuels (VLANs 1-4094).

Q1 : En observant la capture d'écran des résultats de la commande show int trunk, donnez deux preuves visuelles distinctes qui montrent que le port de l'attaquant (Eth0/2) n'est pas un lien Trunk légitime comme les ports Eth0/1 et Eth0/3 ?

Q2 : Quelle est la différence fondamentale entre un port configuré en mode Access et un port configuré en mode Trunk ?

Q3 : Quel est l'intérêt pour l'attaquant de forcer la négociation de son port en mode Trunk plutôt que de rester en mode Access ?

illustration : négociation du lien trunk en eth0/2



Défense 3 : Désactivation de la négociation DTP

Contexte : *Les gardiens s'aperçoivent du coup fourré et par la suite font construire un plafond sur l'enclos. Alex ne peut plus escalader.*

Objectif de la défense : Figer définitivement une interface en mode d'accès standard pour empêcher toute négociation dynamique et non autorisée d'un port en mode trunk, bloquant ainsi les tentatives d'évasion (VLAN Hopping) vers d'autres réseaux virtuels.

Switch1(config)# int eth0/2
Switch1(config-if)# switchport mode access
Switch1(config-if)# switchport nonegotiate

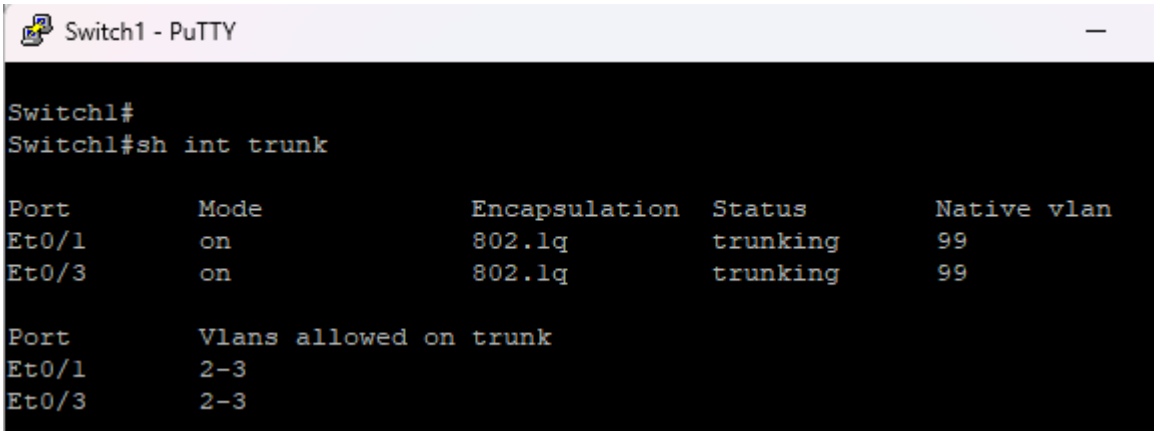
Résultat : le port de l'attaquant (Eth0/2) a disparu de la liste des liaisons trunk, confirmant qu'il est désormais verrouillé en mode d'accès standard et qu'il ne peut plus s'échapper vers les autres VLANs.

Q1 : Pourquoi laisser un port de switch en mode "négociation automatique" (DTP) est-il dangereux lorsqu'un utilisateur malveillant y est branché ?

Q2 : Quelle commande spécifique permet de forcer une interface à ne plus envoyer ni accepter de messages de négociation DTP ?

Q3 : En plus de désactiver la négociation, quel mode doit-on configurer explicitement sur un port relié à un PC pour garantir qu'il ne devienne jamais un lien d'interconnexion ?

illustration : disparition de liaison trunk



Attaque 4 : MAC Flooding

Contexte : *Avec l'aide des singes et de leur mitraillette à bananes, Alex va inonder la salle de contrôle de centaines de milliers de bananes causant ainsi le déclenchement de l'alerte générale du zoo et l'ouverture de la porte de son enclos.*

Objectif de l'attaque : Saturer la mémoire du switch en l'inondant de milliers de fausses adresses MAC par secondes, le forçant ainsi à se comporter comme un simple concentrateur (Hub) qui diffuse tout le trafic réseau en clair, permettant à l'attaquant de l'intercepter.

Préparatif : copier la configuration en cours vers la configuration de démarrage au cas où le switch s'éteindrait complètement suite à l'attaque.

Switch1# copy run start

On utilisera l'outil macof pour envoyer les adresses MAC aléatoires directement au switch par le port eth0/2.

debian@debian:~$ sudo macof -i ens3

Résultat : Nous pouvons constater dans la table d'adresses MAC du Switch1 juste avant qu'il soit hors service, des milliers d'adresses MAC. Cette attaque entraînera un déni de service (DoS) sur le switch que l'on peut vérifier rapidement avec un ping.

Q1 : L'outil d'attaque macof génère des milliers de trames avec des adresses MAC sources aléatoires. Quelle table spécifique du switch l'attaquant cherche-t-il à saturer avec cette méthode ?

Q2 : Que se passe-t-il exactement lorsque cette table est pleine et que le switch reçoit une trame légitime destinée à un utilisateur normal ?

Q3 : Dans la théorie, en forçant le commutateur à adopter ce comportement de "diffusion générale" (fail-open), quel est l'intérêt technique pour l'attaquant et que peut-il désormais faire avec un logiciel comme Wireshark ?

illustration : table d'adresses MAC surchargée

Switch1 - PuTTY

```
Switch1#show mac address-table count

Mac Entries for Vlan 1:
---------------------------
Dynamic Address Count  : 0
Static  Address Count  : 0
Total Mac Addresses    : 0

Mac Entries for Vlan 3:
---------------------------
Dynamic Address Count  : 21011
Static  Address Count  : 0
Total Mac Addresses    : 21011
```

illustration : échec du ping du PC2 vers son routeur

PC2 - PuTTY

```
PC2> ping 192.168.3.251

host (192.168.3.251) not reachable

PC2>
```

Défense 4 : Port Security

Contexte : *Constatant le traquenard, une nouvelle règle est instaurée : limitation stricte à une banane par salle. Si plusieurs bananes arrivent, la porte est scellée automatiquement.*

Objectif de la défense : Prévenir les attaques par inondation (MAC Flooding) et les connexions non autorisées en limitant strictement le nombre d'adresses MAC permises sur un port d'accès, bloquant ou désactivant automatiquement l'interface en cas de violation.

Switch1(config)# int eth0/2
Switch1(config-if)# switchport port-security
Switch1(config-if)# switchport port-security maximum 1
Switch1(config-if)# switchport port-security violation shutdown

Résultat : On constate que la défense à fonctionné car la table d'adresses MAC de Switch 1 ne contient que 1 adresse MAC et le port eth0/2 à été mis en quarantaine. En effet le switch a immédiatement détecté la menace et mis le port de l'attaquant quarantaine.

Q1 : Comment le switch détermine t-il l'@MAC de l'ordinateur légitime parmi les milliers d'adresses MAC ?

Q2 : Quelle est la différence fondamentale entre un port en err-disable et un port qui aurait été désactivé manuellement par un administrateur avec la commande shutdown ?

Q3 : Quelles sont les commandes pour réactiver un port désactivé automatiquement par le switch ?

illustration : mise en quarantaine (err-disable) du port eth0/2 par le Port Security

```
Switch1#
*Mar 20 21:37:45.401: %PM-4-ERR_DISABLE: psecure-violation error detected on Et0
/2, putting Et0/2 in err-disable state
Switch1#
*Mar 20 21:37:45.401: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occ
urred, caused by MAC address dcc2.8968.0154 on port Ethernet0/2.
Switch1#
*Mar 20 21:37:46.404: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/
2, changed state to down
Switch1#
*Mar 20 21:37:47.403: %LINK-3-UPDOWN: Interface Ethernet0/2, changed state to do
wn
Switch1#
```

Attaque 5 : DoS et STP Spoofing

Contexte : *Alex profitera de la pagaille pour s'infiltrer dans le bureau du directeur (salle n°99). Il n'a plus qu'à utiliser les droits du patron pour ouvrir les cages de ses collègues.*

Objectif de l'attaque : Déstabiliser l'infrastructure en l'inondant de requêtes de configuration (BPDU), puis d'usurper le rôle de pont racine (Root Bridge) en annonçant une priorité absolue, afin de forcer tout le trafic du réseau à transiter par la machine de l'attaquant.

Préparatifs : Désactiver le Port Security, réactiver le port eth0/2 coupé par Port Security. Il faut passer le port eth0/2 dans la vlan99 (native) (parler de l'enjeu de la vlan native).

Switch1(config)# int eth0/2
Switch1(config-if)# shutdown
Switch1(config-if)# no shutdown
Switch1(config-if)# switchport access vlan 99
Switch1(config-if)# no switchport port-security

Dans un premier temps nous allons effectuer une attaque DoS via yersinia dans le but d'isoler les équipements.

debian@debian:~$ sudo yersinia -I

Touche i : sélectionner la carte

Touche g : STP

Touche x : attaques

Touche 2 : sending BPDU

Une fois le DoS réalisé, nous allons pouvoir déclarer la machine attaquante comme pont racine.

debian@debian:~$ sudo yersinia -I

Touche i : sélectionner la carte

Touche g : STP

Touche x : attaques

Touche 4 : claiming root role

Résultat : l'interface de l'attaquant (Eth0/2) a pris le rôle de port racine (Root FWD), confirmant qu'il a réussi à manipuler la topologie Spanning-Tree pour s'imposer comme le chemin principal du réseau et ainsi détourner le trafic.

Q1 : Quel paramètre spécifique contenu dans ces trames l'attaquant doit-il abaisser artificiellement pour forcer les autres commutateurs à l'élire comme le Pont Racine (Root Bridge) ?

Q2 : Si le PC de l'attaquant réussit à s'imposer comme le nouveau *Root Bridge*, quel sera l'impact direct sur le chemin emprunté par les données légitimes circulant entre deux autres ordinateurs du réseau ?

Q3 : Lors de l'attaque avec Yersinia, si l'attaquant envoie des trames BPDU en boucle le réseau devient inutilisable (Déni de Service). Pourquoi les commutateurs légitimes s'arrêtent-ils de faire circuler le trafic normal dans cette situation ?

illustration : récupération du rôle Root sur la Vlan 99

```
Switch1#
*Mar 20 22:07:15.590: %SYS-5-CONFIG_I: Configured from console by console
Switch1#sh spanning-tree vlan 99

VLAN0099
  Spanning tree enabled protocol rstp
  Root ID    Priority    32867
             Address     aabb.cc00.0300
             Cost        100
             Port        3 (Ethernet0/2)
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    32867  (priority 32768 sys-id-ext 99)
             Address     aabb.cc00.0400
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time  300 sec

Interface           Role Sts Cost      Prio.Nbr Type
------------------- ---- --- --------- -------- ----------------------------
Et0/2               Root FWD 100       128.3    Shr


Switch1#
```

Défense 5 : BPDU Guard

Contexte : *Bien conscient de la mascarade, le directeur installe une serrure à reconnaissance biométrique. A la moindre intrusion, les gardiens sont appelés et l'intrus est renvoyé du zoo.*

Objectif de la défense : Sécuriser l'infrastructure en désactivant immédiatement tout port d'accès utilisateur dès la réception d'un paquet de configuration Spanning-Tree (BPDU), empêchant ainsi un attaquant de modifier l'architecture ou d'usurper le rôle de pont racine.

Switch1(config)# int eth0/2
Switch1(config-if)# spanning-tree bpduguard enable

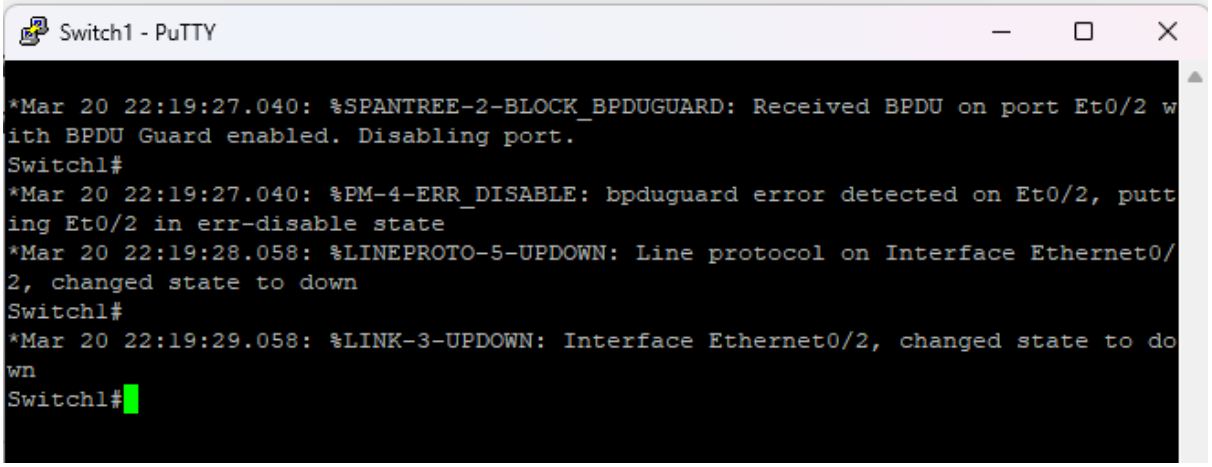
Résultat : dès la réception d'un paquet de configuration Spanning-Tree illégitime, le switch a instantanément verrouillé le port de l'attaquant (Et0/2) en état d'erreur (err-disable), stoppant net toute tentative de prise de contrôle du réseau.

Q1 : Est-ce normal de recevoir des paquets BPDU sur un port d'accès ?

Q2 : Sur quels types de liaisons est-il judicieux d'activer le mode portfast ?

Q3 : Avec BPDUGuard sous quel état un port finit t-il à la réception d'un paquet BPDU illégitime ?

illustration : mise en quarantaine (err-disable) du port eth0/2 par BPDUGuard



IV - Annexe

1. Outils à installer sur les postes

PC3 attaquant : Yersinia, Macof et Arpspoof

2. Manuel d'installation des outils (Yersinia, Macof et Arpspoof)

Avant toutes installations :
debian@debian:~$ sudo apt update

Pour Yersinia :
debian@debian:~$ sudo apt install yersinia -y

Pour Macof et Arpspoof :
debian@debian:~$ sudo apt install dsniff -y

3. Manuel d'utilisation des outils

Yersinia :

Lancement de l'outil avec la commande :

debian@debian:~$ sudo yersinia -I

Une fois dans yersinia, **sélectionner l'interface** de votre machine (ens3) avec la **touche i**.

illustration : interface graphique de yersinia

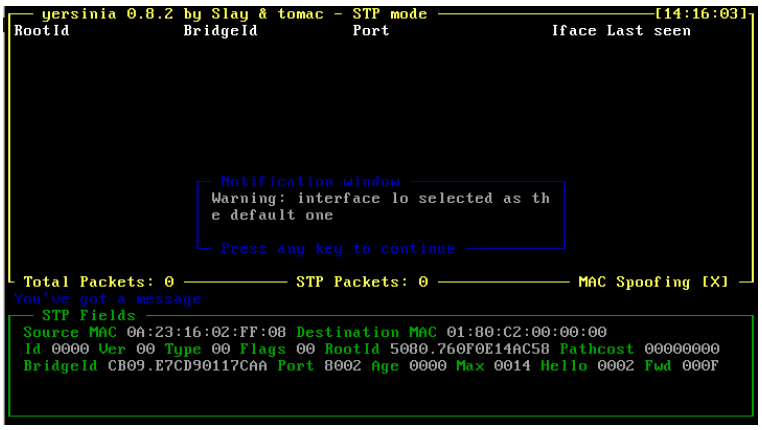
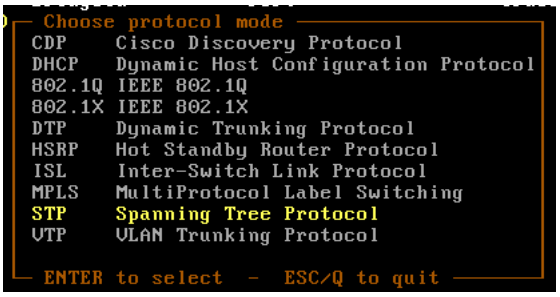


illustration : choix de l'interface

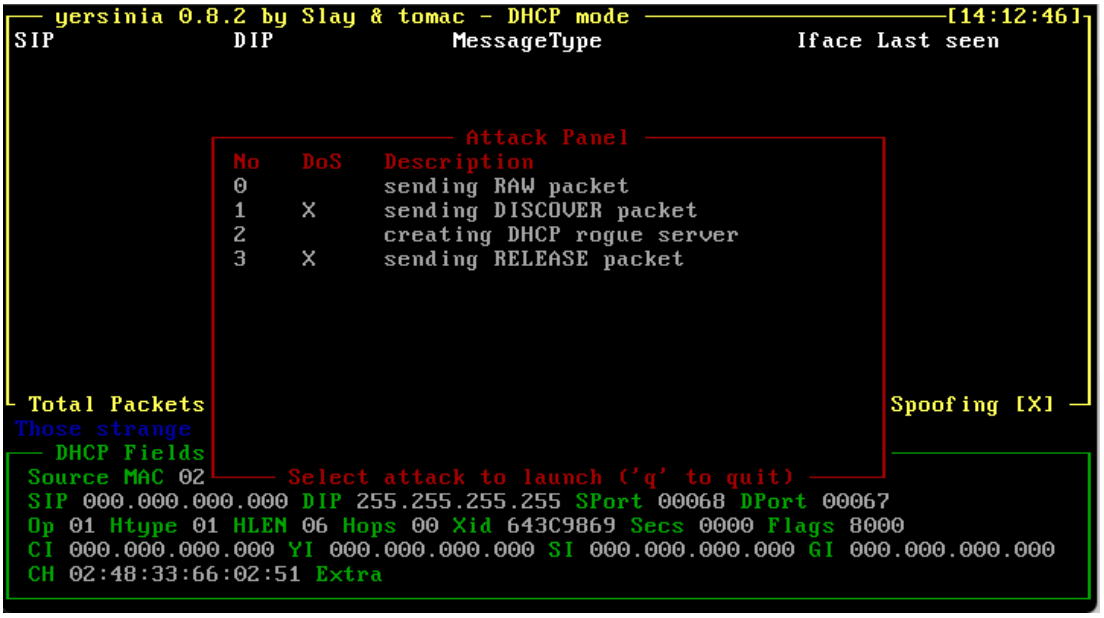
Avant de lancer une attaque il faudra d'abord **choisir le protocole** que vous souhaitez attaquer, pour ouvrir ce menu utilisez la **touche g**.

illustration : menu des protocoles



Une fois le protocole choisi, Yersinia propose une multitude d'attaques allant du simple DoS au Man in The Middle. **Touche x** pour **ouvrir le panel d'attaques**

illustration : panel d'attaque



Macof :

Macof n'est pas un outil isolé, c'est un utilitaire écrit en langage C qui fait partie de la célèbre suite d'outils de sécurité dsniff. À l'origine, cet outil a été conçu pour les administrateurs réseau afin de tester la résistance de leurs propres commutateurs (stress-test de la mémoire CAM).

L'utilisation que nous allons en faire va permettre d'inonder des équipements d'adresses MAC aléatoires. Pour démarrer l'inondation, tapez la commande suivante

debian@debian:~$ sudo macof -i <votre_interface>

Arpspoof :

Issu de la célèbre suite de sécurité dsniff, arpspoof est l'outil de référence pour mener des attaques furtives de type Man in the Middle sur un réseau local. Plutôt que de paralyser l'infrastructure, il vise à rediriger silencieusement le trafic en exploitant la vulnérabilité fondamentale du protocole ARP : son absence d'authentification. Pour ce faire, l'outil forge et diffuse en boucle des réponses non sollicitées ("Gratuitous ARP") à une machine cible, lui faisant croire qu'il possède l'adresse MAC du routeur légitime. La victime met alors aveuglément à jour son cache ARP et se met à envoyer tout son trafic réseau directement à l'attaquant.

debian@debian:~$ sudo arpspoof -i ens3 -t <@IP Cible> <@IP Usurpation>

FIN DU TP